星河虚拟银行 Agent

技术文档

系统架构 · 核心算法 · 安全设计 | 安全加固版（2026-11-01）

项目名称	星河虚拟银行 Agent（本地合成数据教学原型）
文档类型	技术文档（架构、算法、安全设计三合一）
代码基线	收款人核对版 → Agent-API 智能版 → 安全加固版（2026-11-01）
运行环境	Windows 10/11 x64，Python 3.11+（纯标准库，无第三方运行时依赖）
文档版本	V1.0
编制日期	2026-11-01
密级	公开（参赛材料）

本文件描述的全部账户、交易、股票、商户、身份与风控数据均为本地合成样例；系统不连接真实银行、证券、征信或身份服务，不构成任何投资建议或真实支付能力证明。

文档说明

1. 编制目的

本文件面向评审专家与后续维护者，完整说明星河虚拟银行 Agent 的架构划分、关键算法与服务端安全设计。编写原则是“只写代码里已经存在的行为”：每一条控制、阈值与状态迁移都能在仓库中找到对应实现位置，文档不把规划中的能力写成本次已交付的功能。

2. 阅读指引

表 1 阅读路径建议

读者	建议路径
评审专家	第 1 章 → 第 2 章（图 1、图 3）→ 第 3 章 3.5—3.7 → 第 4 章 → 第 7 章
后端 / 算法同学	第 2.3 节模块映射 → 第 3 章全部 → 第 5 章接口与数据模型
安全 / 合规同学	第 4 章 → 配套《安全自评报告》（权限分级、风险清单、测评证据）
运维 / 演示同学	第 6 章部署与运行 → 第 7 章测试与验证

3. 版本与基线

代码基线为 2026-10-29 的“收款人核对版 + Agent-API 智能版”，2026-11-01 完成一轮安全加固（本版）。加固后在仓库 `banking_agent/` 下共 15 个 Python 文件、5 662 行代码（其中模拟业务适配器 `demo.py` 约 2 200 行），另有 4 个前端静态资源；测试 10 个模块、162 个用例。本次文档编制过程中执行了全量回归、29 项 HTTP 黑盒探测与代码级复核，结果记录在第 7 章及配套《安全自评报告》。

4. 技术要点速览

- **零第三方依赖**：服务端、前端、测试全部使用 Python 标准库与原生 HTML/CSS/JS，Windows 免安装包内置经 SHA-256 校验的 CPython 3.13 运行时，可在离线机器上一键启动。

- **规则 + 模型双通道**：未配置模型时由确定性中文规则解析器驱动；配置 OpenAI 兼容接口后，由大模型通过 Function Calling 提出**类型化操作**，服务端按白名单与类型强校验后才进入业务流程。
- **六道服务端闸门**：配置校验 → 字段完整性 → 认证等级 → 风险合并（只升不降）→ 预览摘要确认 → 审计先行与幂等执行，任何一道失败都不会跨越资金边界。
- **两类可解释的授权例外**：网页小于 3000 元的单次即时转账、已确认的计划范围授权。两类都有写死的边界、执行前复验与审计事件，不伪称“用户点击了确认”；虚构股票买入在加固版中已取消免确认路径。
- **可验证而非仅声明**：162 项自动化用例（全部通过）+ 29 项 HTTP 黑盒探测（全部符合预期），关键控制均有代码行号与实测输出支撑。

目 录

文档说明 2

1. 编制目的 • 2. 阅读指引 • 3. 版本与基线 • 4. 技术要点速览

1 概述 5

1.1 项目定位 • 1.2 设计目标 • 1.3 范围与边界 • 1.4 术语与缩略语

2 系统架构 8

2.1 架构总览 • 2.2 部署与运行视图 • 2.3 模块职责与代码映射 • 2.4 双通道意图理解 • 2.5 关键时序：首次收款人转账 • 2.6 任务状态机 • 2.7 认证、会话与限额模型 • 2.8 数据生命周期

3 核心算法 16

3.1 主处理流水线 • 3.2 中文意图解析（规则通道） • 3.3 大模型规划与工具调用 • 3.4 收款人解析与首次身份核对 • 3.5 认证与风险合并 • 3.6 预览、摘要与确认 • 3.7 两类可解释的授权例外 • 3.8 金额、精度与舍入 • 3.9 虚构股票计价与持仓 • 3.10 账单汇总与启发式分析 • 3.11 预算预留与范围授权 • 3.12 多层幂等与状态核验 • 3.13 审计哈希链 • 3.14 复杂度与适用范围

4 安全设计 23

4.1 安全目标与安全假设 • 4.2 威胁模型与信任边界 • 4.3 网络与浏览器侧控制 • 4.4 会话与并发 • 4.5 认证与风险控制 • 4.6 授权与确认 • 4.7 执行与幂等 • 4.8 隐私与数据最小化 • 4.9 审计 • 4.10 大模型接入安全 • 4.11 供应链与交付完整性

5 接口与数据模型 27

5.1 本机 HTTP 接口 • 5.2 核心数据模型 • 5.3 工具协议 • 5.4 审计事件结构

6 部署与运行 29

6.1 环境要求 • 6.2 启动方式 • 6.3 主要配置项 • 6.4 模型通道配置 • 6.5 常见问题

7 测试与验证 31

7.1 测试组织 • 7.2 本次实测结果 • 7.3 验证边界

附录 A 演示脚本与预期现象 33

附录 B 文件清单 34

1 概述

1.1 项目定位

星河虚拟银行 Agent 是一个**规则驱动、工具编排、带任务状态机**的虚拟银行智能体原型。用户通过中文对话或网页表单表达意图，系统将意图转换为结构化的 `OperationRequest`，依次经过字段校验、认证、风险合并、授权与审计，最后调用内存中的模拟银行工具完成办理。系统同时提供两种前端：本机网页工作台（`127.0.0.1`，含聊天、表单、确认按钮与首次收款人核对弹窗）与命令行演示（`python -X utf8 -m banking_agent --demo`）。

项目的技术价值不在于“能聊天办业务”，而在于**把对话式交互的不确定性收敛到一条可审计、可拒绝、可复现的控制链路上**：自然语言（或大模型）只能提出意图，不能直接产生资金动作；每一条资金动作都必须通过服务端独立形成的风险判断、用户可见的摘要确认、审计落盘与幂等执行。

1.2 设计目标

表 2 设计目标与落地映射

目标	落地方式	验收证据
失败关闭	配置缺失、工具缺失、字段异常、审计不可用时一律拒绝办理，绝不“带着不确定性放行”	`test_unconfigured_agent_fails_closed`；审计失败熔断实测
风险只升不降	操作风险下限与工具评估取较大值，人工审核标记强制 R4；调用方无法通过提交低等级覆盖	`policy.effective_risk`；10000 元实测进入审核且不扣款
对话不可直接授权	模型/解析器只能提出操作；确认由服务端一次性 nonce 与摘要共同校验，认证等级只由服务端会话状态决定	`agent.confirm`；`web_app.apply_authentication`
重复不重复扣款	请求编号指纹、执行幂等键、超时按原键查询三层防护，未知状态只查不重试	3 路并发同一 request_id 实测仅扣一次
可观测与可追溯	关键节点写本地 JSONL 审计，标识符 HMAC 化，SHA-256 哈希链防篡改，append 后 fsync	`audit.py`；篡改检测用例

1.3 范围与边界

为避免误解，下表明确区分“本次已实现”与“明确未实现”。项目对外部世界的唯一网络调用是**可选的**大模型 API（HTTPS）；除此之外不联网，也没有真实资金、真实身份或真实行情。

表 3 范围与边界

维度	本次已实现	明确未实现（不宣称）
业务	余额、流水、账单分析、转账（即时/定时/周期）、AA、理财申赎、虚构股票、卡片、订阅、生日采购计划、争议、预算与提醒、组合计划	真实开户、真实支付清算、真实证券交易、真实信贷与征信
智能	确定性中文规则解析；可选大模型 Function Calling 规划；模板化解释文案	模型训练/微调、RAG、向量检索、多智能体自主规划
安全	认证分级、风险分级与审核队列、摘要确认、三类授权例外、幂等、哈希链审计、脱敏	真实登录/MFA、真实 RBAC 与双人复核、HSM/KMS、WORM 存储、渗透测试与合规认证
数据	进程内内存状态 + 本地 JSONL 审计	数据库、事务、跨进程/跨机一致性、备份与灾备
运维	单机一键启动、免安装运行时、CI 双平台回归	分布式部署、限流网关、监控告警、灰度发布

1.4 术语与缩略语

表 4 术语表

术语	含义
OperationRequest	结构化的业务请求：操作类型、用户/会话标识、摘要、payload、渠道
AgentTask	一次办理过程中的任务实例，携带状态、风险、预览、幂等键与结果
effective_risk	有效风险等级：操作下限与工具评估取较大值，人工审核标记强制 R4
预览摘要（digest）	对公开预览字段与风险信息做规范化序列化后的 SHA-256，用于绑定“用户确认的内容”
确认门 / 身份核对门	服务端在资金动作前设置的强制停点；前者核对金额与影响，后者核对首次收款人
幂等键（idempotency_key）	一次执行对应的唯一标识，工具与状态查询都以它为键，防止重复扣款
R0—R4	风险等级，R4 表示必须人工审核，绝不自动执行

术语	含义
NONE / STANDARD / ENHANCED / MANUAL	认证强度等级，变更类操作最低要求 ENHANCED

2 系统架构

2.1 架构总览

系统按职责划分为六层：交互层、接入与会话层、意图理解层、编排核心层、工具适配层、数据与审计层。层间通过明确的数据结构（`OperationRequest`、`AgentTask`、`OperationPreview`、`ExecutionResult`）通信，上层不直接操作下层内部状态。



图 1 系统总体架构（分层视图）

需要强调：这是一张**模块关系图**，不是微服务拓扑。`SimulatedBank` 的同一个实例同时实现认证、风控、查询、收款人解析、预览、执行、状态查询与审核 8 个工具协议；每个浏览器会话拥有独立的 Agent、模拟银行与审计文件。

表 5 分层职责

层次	组成	职责边界
① 交互层	浏览器工作台、命令行演示	收集意图与确认动作；不做任何权限或风险判断
② 接入与会话层	`LocalBankServer`、`LocalBankHandler`、`BrowserSession`	回环监听、Host/Origin/CSRF 校验、请求体限制、会话隔离、请求去重与版本控制
③ 意图理解层	`DemoConversation`（规则）、`ModelConversation`（大模型）	把自然语言转为类型化操作；不得携带认证、风险或内部引用
④ 编排核心层	`BankingAgent`、`BankingWorkflow`、`policy`、`config`	任务状态机、认证、风险合并、预览与确认、幂等执行、状态核验
⑤ 工具适配层	`ToolRegistry`、`SimulatedBank`、`SyntheticStockMarket`	在受信侧执行业务；输出经过脱敏后才会回到上层
⑥ 数据与审计层	会话内存字典、`AuditLog`	状态存放与可追溯性；审计是资金动作的前置条件

2.2 部署与运行视图

系统以“一台电脑、一个 Python 进程、若干个相互隔离的浏览器会话”的形态运行。服务端只接受 `127.0.0.1` 绑定（构造函数强校验），默认选择一个空闲端口，启动后自动打开浏览器。会话之间通过独立的 `BrowserSession` 对象隔离，每个会话拥有自己的 Agent、模拟银行状态和审计文件。

表 6 交付形态

形态	入口	运行时	适用场景
源码运行	`launch_demo.py --web` / `-m banking_agent --demo`	本机 Python 3.11+，零第三方依赖	开发、评审复现
Windows 免安装	`启动网页演示.cmd`	包内 `runtime/` CPython 3.13（SHA-256 校验后内置）	离线分发、课堂演示
命令行	`启动演示.cmd` / `-m banking_agent --demo`	同上	无浏览器环境、教学讲解

2.3 模块职责与代码映射

表 7 模块职责与代码映射

模块	职责	关键入口	规模
web_app.py	本机 HTTP、会话、请求校验、网页策略、首次收款人核对	LocalBankServer、BrowserSession	525 行
agent.py	任务状态机、认证、风险、预览、确认、幂等执行、审计写入	BankingAgent.submit/confirm	1 005 行
policy.py	操作风险下限、有效风险合并、所需工具	effective_risk、minimum_risk	90 行
models.py	请求/任务/预览/结果数据模型与公开化、脱敏	OperationRequest、AgentTask	265 行
config.py	配置项、缺失字段与阈值合法性检查	AgentConfig.missing_fields_for	103 行
tools.py	9 个工具协议与注册表	ToolRegistry	111 行
demo.py	全部合成业务数据与模拟工具实现	SimulatedBank、build_demo_agent	2 113 行
llm_client.py	OpenAI 兼容传输、URL/响应校验、密钥擦除	OpenAICompatibleClient	237 行
llm_agent.py	模型工具白名单、参数强校验、单轮单变更	ModelConversation	501 行
workflow.py	多步骤依赖串联	BankingWorkflow.advance	107 行
stocks.py	虚构股票报价、费用、持仓成本	SyntheticStockMarket	75 行
audit.py	JSONL 追加、哈希链、fsync、启动校验	AuditLog	82 行
privacy.py	敏感字段拒绝、输出脱敏	redact_text、redact_tool_output	69 行

2.4 双通道意图理解

系统保留两条互斥的意图通道，由“是否配置模型 + 请求来源”决定，二者都不具备执行权限：

表 8 双通道对比

维度	规则通道（默认）	模型通道（可选）
实现	`DemoConversation._parse`：关键词 + 正则 + 内置代码表	`ModelConversation`：Function Calling + 服务端强校验
确定性	完全确定，同一输入必得同一结果	不确定，需服务端二次校验兜底
联网	不联网	仅调用用户配置的 HTTPS 模型接口
能力边界	受限于规则覆盖；不支持任意自然语言	支持同义表达与上下文指代；仍受 schema 与业务规则约束
失败表现	缺字段 → 追问；无法识别 → 明确提示	模型异常 → 固定文案降级，**不自动改用关键词通道办理**
安全定位	由代码作者保证解析结果可预期	把模型输出当作不可信输入，逐字段校验

设计取舍

引入大模型提升的是“理解体验”，不是“权限”。模型无法提交认证字段、风险等级、内部收款人引用，也无法代替用户点击确认；一旦模型输出越界，服务端按固定文案拒绝并说明“本轮未办理”。

2.5 关键时序：首次收款人转账

以初始活期余额 50 000.00 元、输入“给张三转账 2888 元”为例。这是网页普通即时转账的成功路径，任何一处校验失败都会中断并如实返回状态，而不是“尽力办理”。

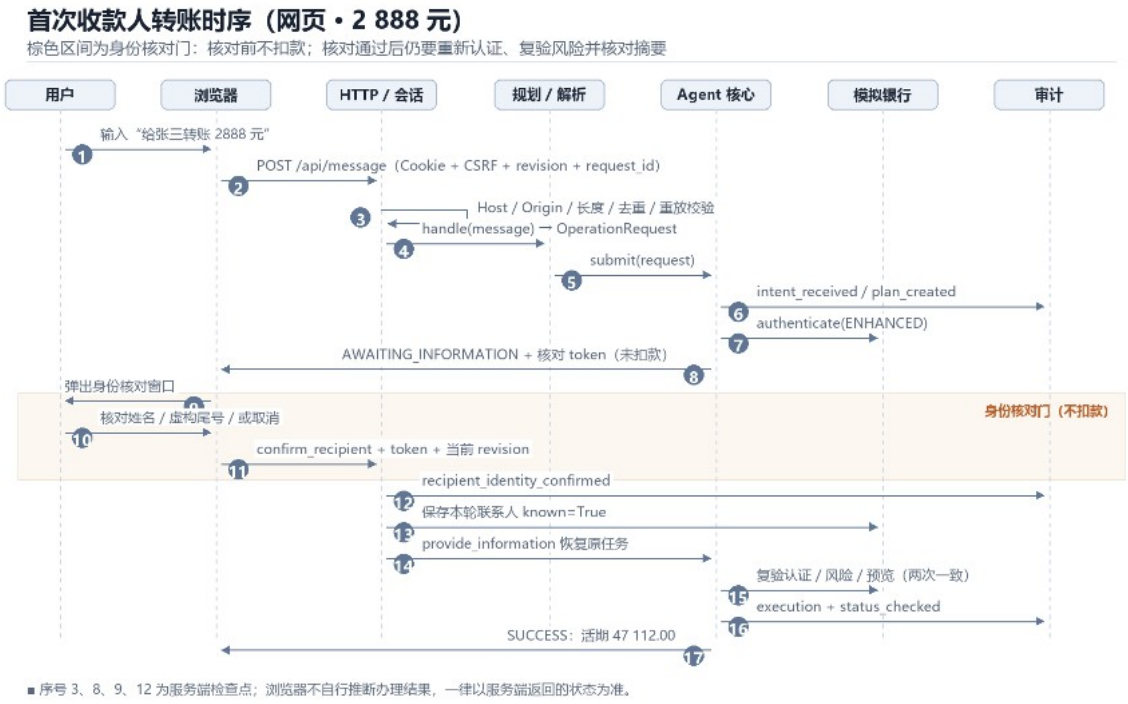


图 2 首次收款人转账时序

表 9 时序关键约束

序号	动作	关键约束
②—③	浏览器提交 JSON，服务端做 Host / Origin / CSRF / revision / 去重校验	任一不通过直接 403/409/413/415，不进入业务
⑤	提交 `OperationRequest` 并写 `intent_received` / `plan_created` 审计	审计失败立即熔断
⑥	`authenticate(ENHANCED)`	变更类操作最低 ENHANCED
⑦	识别为新收款人 → `AWAITING_INFORMATION` + 核对 token	**此刻不扣款、不保存联系人**
⑧—⑪	弹窗核对姓名与虚构尾号，回传 token 与当前 revision	token 与任务、会话版本绑定；重放无效
⑫—⑬	先写身份确认审计，再保存 `known=True` 联系人，然后恢复原任务	审计先于写状态；失败则暂停
⑭	重新认证、重新评估风险、重新生成预览并比对摘要	两次预览一致才继续
⑮—⑯	审计先写，再置 `PROCESSING`，用唯一幂等键执行并按同一键查状态	结果以工具返回为准

2.6 任务状态机

每个任务在 `DRAFT → … → 终态` 之间迁移，状态由服务端维护并在网页回显。所有资金动作必须经过 `AWAITING_CONFIRMATION` 与 `PROCESSING`；`UNKNOWN` 只允许按原幂等键查询，绝不重新提交。

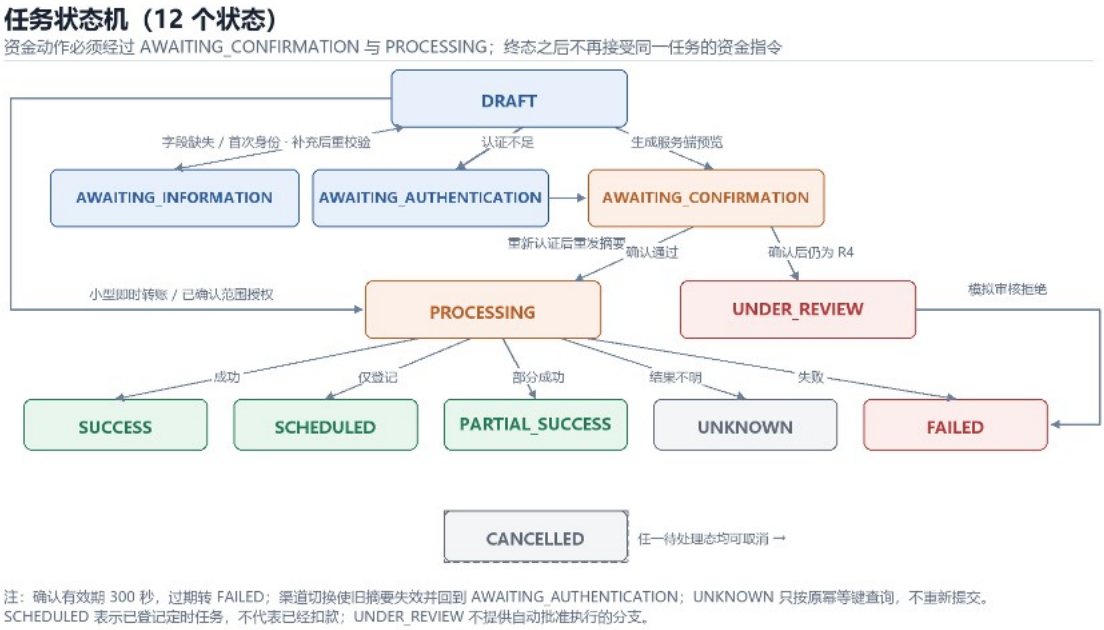


图 3 任务状态机（12 个状态）

表 10 状态语义

状态	语义	是否允许资金动作
DRAFT	请求已登记，尚未完成字段与认证检查	否
AWAITING_INFORMATION	缺少必填字段、需选择同名收款人、或等待首次身份核对	否
AWAITING_AUTHENTICATION	认证等级不足，等待回到 APP 渠道重新认证	否
AWAITING_CONFIRMATION	已生成预览与确认短语，等待用户确认	否（仅确认入口可用）
UNDER_REVIEW	R4 请求已进入模拟审核队列	否，且无自动批准分支
PROCESSING	已提交工具、尚未拿到可信状态（含已受理的投资订单）	执行中，禁止重入
SCHEDULED	定时任务已登记，**未扣款**	否
SUCCESS / PARTIAL_SUCCESS	工具返回成功 / 部分步骤成功	终态
FAILED	校验失败、确认过期、审核拒绝或工具失败	终态

状态	语义	是否允许资金动作
UNKNOWN	已提交但结果无法确认	只允许查询原幂等键
CANCELLED	用户取消（不撤销已完成交易）	终态

2.7 认证、会话与限额模型

加固版把“谁能证明自己”与“谁说了什么”彻底分开，认证、会话与限额三者的状态全部落在服务端。

表 11 认证、会话与限额机制

机制	实现	解决的问题
服务端渠道	`BrowserSession.chat.channel` 是唯一渠道来源；`SimulatedBank.bind_channel_source()` 读取它，`OperationRequest.channel` 只作展示，不参与认证	请求参数或对话文本无法改变认证等级
会话身份绑定	每个会话生成 `web-<随机>` 标识，`bind_identity()` 后适配器只接受这一组 `(user_id, session_id)`	跨会话伪造身份不可行，审计可归因到会话
一次性演示安全码	`AuthChallenge` 用 `secrets` 生成 6 位码，5 分钟有效；校验通过后立即轮换	“切换到 APP”这类话术不再能提权，码被截获也只能用一次
确认 nonce	任务进入待确认时生成 `secrets.token_urlsafe(24)`，确认成功后立即作废	确认凭据不能由 csrf 与摘要推导，也不能重放
进程级限额账本	`TransferLedger` 以（业务日，账户尾号）累计，跨会话共享	多开标签页或新会话无法重置当日额度
会话淘汰	上限 30 + 30 分钟空闲回收 + LRU 淘汰 + Cookie `Max-Age`	占满会话不再等于永久拒绝服务

需要强调：演示安全码只是把“认证动作”从口头指令变成一次明确的服务端校验，页面本身会显示这个码，它模拟的是验证器而不是真实身份。真正的身份核验仍需接入真实登录与 MFA。

2.8 数据生命周期

表 11 数据生命周期

数据	存放位置	生命周期
账户、联系人、交易、卡片、订阅、持仓、预算与计划	各会话 `SimulatedBank` 的字典/列表	刷新保留；重置或进程重启恢复样例

数据	存放位置	生命周期
任务、请求指纹、幂等结果	Agent 与会话内存	进程内有效，不跨进程、不持久化
聊天消息与待核对收款人	BrowserSession	同一 Cookie 会话内
审计事件	data/web-<随机>.jsonl（网页）/ data/demo-audit.jsonl（命令行）	文件保留；重置不删除旧文件
模型密钥	仅进程内存 APIConfig（repr=False）	会话结束或断开即消失，不落盘
启动异常	data/startup-error.log	出错时写入，可能含本机绝对路径

3 核心算法

本章所称“算法”指仓库内已实现的确定性规则、校验逻辑与状态转换，不包含机器学习训练、真实反欺诈模型或投资预测。每个小节给出实现位置、判定条件与可验证现象。

3.1 主处理流水线

一次办理依次通过六道闸门，任一道失败即停止并落在明确状态上：

```
中文输入 / 表单
  → ① 配置与工具完整性检查（缺一即 FAILED: agent_not_configured）
  → ② 必填字段检查（缺字段 → AWAITING_INFORMATION，可补充后重校验）
  → ③ 认证检查（查询 ≥ STANDARD，变更 ≥ ENHANCED，不足 → AWAITING_AUTHENTICATION）
  → ④ 收款对象解析 + 风险合并（effective_risk，只升不降；R4 → 审核）
  → ⑤ 服务端预览 + 摘要 + 确认短语（默认 300 秒有效）
  → ⑥ 审计先行 + 幂等执行 + 按同一键查询结果
```

对应代码集中在 `agent.py` 的 `submit`、`_prepare_account_operation`、`_resolve_and_assess`、`_assess_and_continue`、`_create_preview`、`confirm` 与 `_execute_once`。

3.2 中文意图解析（规则通道）

`DemoConversation._parse` 按顺序匹配关键词与正则，把一句话映射为操作类型与字段。字段提取要点：

表 12 规则解析字段

字段	规则	边界处理
金额	从“数字 + 元/块/人民币/CNY”提取，最多两位小数	负号显式报错；三位小数视为缺失并追问
日期	支持年月日、月份、年份区间；账单可跨期	自定义区间上限 3 660 天；未来日期用于定时任务
收款人	“给/向/为/转给/汇给”前缀 + 姓名边界；网页另有完整姓名优先规则	代词、泛指、多对象连接词拒绝；重名要求选择尾号
用途/备注	按标签提取，截断于下一字段	缺省在网页填充为“日常转账”
操作对象	产品、卡片、订阅、计划使用内置代码或尾号	未知代码不静默匹配

默认值可见原则：网页对短句设置的默认值（活期账户、立即执行、日常转账）都会在预览中展示；而明确写出但无法识别的账户、尾号或未来时间不会静默降级为“立即从活期付款”。

3.3 大模型规划与工具调用

模型只能调用 6 个受控工具：`submit_operation`、`provide_information`、`choose_recipient`、`task_status`、`cancel_task`、`compose_workflow`。服务端对每一次调用做四层校验：

表 13 模型工具调用校验

层	校验内容	违规结果
结构层	工具名必须在白名单内；参数必须是合法 JSON 对象且字段集合完全匹配	固定文案拒绝，本轮不执行
类型层	金额按十进制字符串规范化并限制位数与指数；整数、布尔、列表、枚举逐项校验	类型不符即拒绝
语义层	只允许该业务定义的字段；动作必须在枚举内；账户/卡片/商户必须存在于本轮目录	越界即拒绝
一致性层	对话含外币、假设语气或“暂不执行”时拒绝变更；含未来/周期语义时拒绝被降级为立即付款	拒绝并说明原因

此外还有三条硬约束：**每轮最多一次会改变状态的工具**（多个业务必须走组合计划草稿）、模型不得提交 `recipient_ref`/认证/风险字段、模型输出中的密钥回显会被替换为 `[已隐藏]`。金额格式化前先限制指数范围，避免 `1e1000000000` 这类短字符串在格式化时撑爆内存。

3.4 收款人解析与首次身份核对

网页版 `BrowserDemoConversation._find_recipient` 采用“完整姓名优先”策略，避免把“张小明”解析成已存在的“小明”：

```
explicit_recipient_name(text)
  = 截断“用途/备注/原因”之后的文本
  → 匹配 (转给|汇给|给|向|为) + 2~16 个中文字符/中点
  → 以 转账|汇款|每月|尾号|[数字标点] 为右边界
  → valid_recipient_name：拒绝代词、泛指、操作词、连接词
```

当明确姓名在已核对列表中不存在时，任务暂停为 `AWAITING_INFORMATION`（`error_code=recipient_identity_required`），网页生成一次性核对 token，弹窗展示姓名、模拟银行与 4 位虚构尾号。默认尾号由 `1000 + SHA256(姓名)[:8] mod 9000` 派生，**只用于让同一个虚构姓名有稳定演示尾号，不推算任何真实账户**。

确认路径的校验顺序是：当前 token（compare_digest）→ 会话 revision → 原任务仍处于待补充状态 → 姓名格式 → 4 位数字尾号 → 若改名为已存在联系人则尾号必须与其样例记录一致。通过后先写身份确认审计，再写入 known=True 联系人，随后调用 provide_information 从头重新走认证、风险与金额规则。

3.5 认证与风险合并

风险采用“只升不降”的合并规则，任何调用方都无法通过提交较低等级来降低流程要求：

```
effective_level = max(minimum_risk(operation), tool_assessment.level)
if assessment.manual_review_required:        effective_level = R4
if TRANSFER 或 AA(pay_request):
      amount >= high(10 000) 或 amount >= daily(20 000)  → R4
      否则 amount >= low(1 000)                          → max(level, R3)
if INVESTMENT 且 amount >= investment_confirm_limit(5 000) → max(level, R3)
```

表 14 风险等级与处理

等级	典型操作	核心处理
R0	公共规则说明	公开工具，不查账户
R1	余额、流水、账单、卡片/订阅/持仓查询	≥ STANDARD 认证后查询
R2	分类纠正、预算标签、提醒、临时锁卡、创建计划	≥ ENHANCED，摘要确认
R3	转账、AA、投资、其他卡片与订阅操作、计划执行	≥ ENHANCED，普通路径先确认
R4	诈骗/胁迫信号、限额触发、首次联系收款人、适当性未通过、工具要求人工审核	暂停自动执行，只进审核队列

模拟风控 SimulatedBank.assess 用固定关键词识别“安全账户”“公检法”“屏幕共享”“被监视”等诈骗/胁迫特征，命中即 R4；同时按当日累计金额、首次联系收款人、适当性未通过等情况升级。当日累计按上海日期汇总**当前会话全部账户**，涵盖即时转账、AA 实际付款与手动模拟执行的定时转账——但注意：会话之间相互独立，该累计不是账户级事实（详见《安全自评报告》SEC-03）。

3.6 预览、摘要与确认

预览由工具侧生成，核心只负责“把预览公开化后计算摘要”并绑定到任务：

```
digest = SHA256( canonical_json(preview.public_dict())
                 + "\n"
                 + canonical_json({level, flags, manual_review, rule_ids}) )
```

```
confirmation_phrase = PHRASES[operation]      # 如“确认转账”
confirmation_expires_at = now(utc) + 300s     # confirmation_ttl
```

网页层在摘要之外再加一道**一次性 nonce**：任务进入待确认时由服务端生成随机串并随快照下发，确认请求必须携带同一串，校验通过后立即从任务中删除，因此无法重放、也无法由 `csrf + 摘要` 反推。

`confirm()` 重新执行的检查顺序：任务归属 → 状态仍为待确认 → 渠道未变化 → 未过期 → 确认短语匹配 → 重新认证 → 重新评估风险与重新生成预览 → 摘要是否变化。摘要一旦变化，任务留在待确认并重新签发有效期，不会拿旧条件执行；渠道切换会直接作废旧确认并要求重新认证。

3.7 两类可解释的授权例外

并非“所有变更都二次确认”，但加固后只剩两处显式例外。它们的共同点是：边界写死在代码里、每次执行前复验、并在审计中如实记录“是否收到用户确认”。原先“一键买入虚构股票”不再属于例外——它必须经过同一个确认门。

表 15 两类授权例外

例外	判定条件（全部满足）	保留的检查
网页小额即时转账	操作为转账；`0 < 金额 < 3000`（严格小于）且小数位 ≤ 2；CNY 且零手续费；立即执行、单次；收款人已解析；风险非 R4；工具不要求人工审核；二次预览摘要一致	增强认证、风险复评、审计先行、幂等执行；摘要变化即退回确认
计划范围 / 持续授权	计划已确认建立；计划处于可执行状态且已到采购日；商户在白名单；商品在预算内；单次金额 ≤ 单次上限与剩余预留；累计与单品预算未超；次数与有效期未超	增强认证；新诈骗信号仍可升级 R4 并阻断；一次性授权仍逐次确认

如实记录，而非美化

小额直转使用的审计事件是 `configured_transfer_authorization_used`，字段写明 `required=false, received=false`，不会伪造成“用户点击了确认”。这也是本文档与《安全自评报告》把该路径单列为“授权例外”而不是“确认机制”的原因。

3.8 金额、精度与舍入

全部金额运算使用 Decimal：入口 amount_as_decimal 把任意输入转为 Decimal(str(x)) 并拒绝非有限值；展示与记账统一经 _money() 量化为两位小数（ROUND_HALF_UP）；风险阈值比较前先转 Decimal，避免二进制浮点误差。

加固版在 BankingAgent.submit() 与 provide_information() 的入口调用 _normalize_amounts()，把所有金额字段（含 orders[].amount）按分量化后**回写 payload**，因此预览、摘要、扣款三者使用同一个值：1.005 元在进入流程时就变成 1.01 元，预览与实扣一致。

文本通道另有一道更严的把关：_extract_amount 只接受前面不紧邻字母、小数点、逗号的十进制数字，并显式拒绝科学计数法（1e999）、千分位（1,000,000）、全角数字（１００）与三位以上小数，判定失败即要求用户重述，不会截取其中一段当作金额。

3.9 虚构股票计价与持仓

```
principal     = 固定样例价 × 股数
fee           = round_half_up(principal × 0.001, 0.01)
total         = principal + fee
new_shares    = 旧股数 + 本次股数
new_cost      = 旧成本 + total
average_cost  = new_cost / new_shares          # 展示两位小数
market_value  = 固定样例价 × 持股数
unrealized    = market_value - new_cost
```

示例：XH001 100 股本金 1 280.00 元、手续费 1.28 元、总扣款 1 281.28 元；固定价格下初次浮动盈亏为 -1.28 元，即手续费影响，不是市场预测。股票目录仅有 XH001/XH002/XH003 三只虚构标的，不读取任何实时行情。

3.10 账单汇总与启发式分析

账单先按选定日期区间过滤，再对分类、商户、月份做 Decimal 求和。周期识别规则是：将商户名中的固定虚构后缀标准化后，同一商户出现 ≥ 2 笔且覆盖 ≥ 2 个不同月份，标记为“疑似周期性支出”。该规则**不校验固定扣款日、金额相似度或真实商户合同**，因此输出措辞为“疑似”。异常展示直接读取合成交易自带的 anomaly_features 标签，没有训练异常检测模型；节省建议取支出最高的前两类，在类别金额超过 100 元时提示回看，不自动取消服务或提交争议。

3.11 预算预留与范围授权

计划建立时可按预算预留，可用余额 = 账面余额 − 已预留金额。执行采购时 `_within_purchase_scope` 逐项检查：

(1) 订单金额为正，商品与商户字段完整；商户在计划白名单内；

(2) 重复商品行先聚合，防止“拆行”绕过单品预算；

(3) 本次总额 ≤ 单次上限、≤ 剩余预留、≤ 账户预留；

(4) 累计总支出 ≤ 商品预算合计，且每个商品累计 ≤ 该商品预算；

(5) 执行次数未达上限，当前虚拟日期未超过有效期；

(6) 计划处于可执行状态且已到采购日（或用户显式“模拟到期”）。

全部满足才可能直接执行；任一不满足即拒绝并说明越界维度。新出现的诈骗信号仍可把该计划升级为 R4，使已授权的范围也不能自动扣款。多商品订单逐笔审计与记录，部分成功时不自动重试已完成订单。

3.12 多层幂等与状态核验

表 16 多层幂等

层	键与校验	效果
浏览器请求	`request_id`（8—100 字符）→ 完整请求指纹	同号同内容返回当前快照；同号不同内容 409
核心任务	`(user_id, session_id, request_id)` → payload 指纹	复用任务；指纹冲突返回 `request_id_payload_conflict`
工具执行	`idempotency_key = uuid4()` → `ExecutionResult`	重复执行复用已记录结果
确认凭据	`confirmation_nonce`（`secrets.token_urlsafe(24)`）	校验通过即删除，重放直接 409
状态核验	执行后按同一键 `lookup`	查不到即 `UNKNOWN`，刷新也只查原键

实测：3 路并发提交同一 `request_id` 的 100 元转账，三次请求均返回 200，账户只扣款一次（100.00 元）。

3.13 审计哈希链

```
entry.prev_hash  = previous_event_hash
entry.event_hash = SHA256( canonical_json(entry_without_event_hash) )
追加：进程内 RLock → os.open(O_APPEND, 0o600) → write → fsync
启动：逐行校验 prev_hash 与前链，任何不连续或摘要不符 → AuditError
```

用户、会话标识另用 HMAC-SHA-256 标识化；事件不含原始聊天文本与原始 payload，只记录操作类型、金额、币种、账户尾号、任务/规则/工具/状态、确认摘要与错误码。执行前审计失败会阻止跨越资金边界；提交后审计失败则转为 `UNKNOWN`，不宣称“失败且未扣款”。

3.14 复杂度与适用范围

表 17 复杂度估计

算法	时间开销	空间开销
规则解析	约 $O(K \cdot L)$（K 条规则、L 输入长度）	请求字段与当前输入
收款人解析	当前字典全扫描 $O(R)$	候选列表 $O(R)$
账单汇总	过滤分组 $O(N)$，排序 $O(C \log C) + O(M \log M)$	约 $O(N + C + M)$
股票报价/成交	平均 $O(1)$，持仓展示 $O(P)$	订单随成交次数增长
组合工作流	单次扫描 $O(W)$，逐步推进累计可达 $O(W^2)$	$O(W)$
审计校验/追加	校验 $O(A)$，追加受 fsync 延迟约束	逐行读取，文件随事件增长
去重	字典平均 $O(1)$	随任务数增长，当前不淘汰

上述为当前有限规则的工程估计，不是正则最坏情况证明。系统面向单机教学演示与有限样例数据，未进行高并发、长时间运行或真实数据准确率验证。

4 安全设计

本章说明代码中已经存在的控制与假设。完整的测评结论、缺陷清单与整改建议见配套《安全自评报告》，本章只做设计层面的说明，不复述测评数据。

4.1 安全目标与安全假设

安全目标是避免演示中的误操作、重复扣款、跨会话串数据、跨站提交与错误状态展示，并让每一次资金动作都留下可追溯的记录。

核心假设是：运行机器、Python 程序文件与工具适配器由演示者控制；浏览器提供正常的同源与 Cookie 保护。**恶意本机程序、拥有管理员权限的人、被篡改的代码或恶意浏览器扩展不在本机网页控制的可防御范围内。**

4.2 威胁模型与信任边界

表 18 威胁模型

边界	典型威胁	已实现控制	未覆盖
浏览器 → 本机 HTTP	伪造请求、跨站提交、旧标签重复确认	回环监听、精确 Host/Origin、CSRF、revision、确认 token	本机原生程序可自行构造请求；无用户登录
中文输入 → 请求对象	缺字段、负金额、同名或部分姓名、歧义	规则解析、字段补齐、金额/日期校验、首次收款人核对	不是通用语义理解
模型输出 → 工具调用	越权字段、伪造内部引用、提示注入	工具白名单、逐字段类型校验、单轮单变更、禁止模型确认	模型仍可决定金额与收款人，需服务端策略兜底
预览 → 副作用执行	旧摘要、重复执行、结果不明	摘要绑定、有效期、幂等键、审计先行、执行后查询	无数据库事务与跨进程一致性
内存 → 本地日志	敏感信息外泄、日志被改、磁盘写失败	标识 HMAC、受控字段、哈希链、fsync、失败熔断	无加密、无外部锚定、无 WORM

4.3 网络与浏览器侧控制

- 服务构造期强制 `127.0.0.1`；请求 `Host` 必须精确等于 `127.0.0.1:<端口>`，可抵御 DNS rebinding 与改名访问。

- POST 必须携带与服务器同源的 Origin、application/json、有效会话与 X-CSRF-Token（compare_digest 比较）。
- 请求体非空且不超过 20 000 字节，正文读取 8 秒超时；普通指令 1—3 000 字；非 JSON、非对象一律 400。
- 静态资源只按 /、/app.css、/app.js、/favicon.svg 四条固定路由读取，不拼接用户路径。
- 响应统一带 Cache-Control: no-store、X-Content-Type-Options: nosniff、Referrer-Policy: no-referrer、Permissions-Policy 与限制性 CSP（default-src 'self'、frame-ancestors 'none'、base-uri 'none'）。
- 前端通过 createElement 与 textContent 渲染，不使用 innerHTML，配合 CSP 降低 XSS 面。

4.4 会话与并发

GET /api/state 为浏览器建立随机会话（secrets.token_urlsafe(32)），Cookie 具备 HttpOnly; SameSite=Strict; Path=/; Max-Age=28800。服务端会话表上限 30，但**不再用 503 拒绝**：新会话会先回收 30 分钟无活动的会话，再按最近使用时间淘汰最旧的一个。

连接层设置 10 秒读超时（LocalBankHandler.timeout），并用 BoundedSemaphore(24) 限制同时处理的连接数，超出直接返回 503 并关闭套接字——慢速发送请求头不再能无限占用线程。同一会话的读状态与指令在 RLock 下串行；Agent 内部另有任务级锁。这些是**进程内锁**，不构成数据库事务。

4.5 认证与风险控制

变更操作最低 ENHANCED，普通查询最低 STANDARD，R3 查询额外要求增强认证；confirm、选择收款人、补充信息、刷新审核同样重新认证。风险合并遵循“只升不降”，R4 在确认后进入模拟审核队列，**不存在管理员批准后自动执行的代码分支**。

认证等级只由服务端会话状态给出：请求里的 channel 不参与判定，聊天中的“切换到 APP”只返回一句提示；从 IM 升级到 APP 必须输入页面显示的一次性演示安全码（5 分钟有效、用后轮换）。降级不需要凭据，但会使待确认摘要失效并触发重新认证。

> **诚实声明：这是演示级认证**
>
> 演示安全码把“认证”从一句口头指令变成一次服务端校验，并让每次升级都留下 auth_strengthened

> 审计事件；但页面本身会显示这个码，因此它证明的是“有人在操作这个会话”，不是“这个人是谁”。真实系统仍需接入登录、MFA 与会话吊销，《安全自评报告》把这一项列为仍需生产方补足的能力。

4.6 授权与确认

确认绑定“预览摘要 + 风险信息 + 有效期 + 渠道”，网页再加一道一次性 nonce（`secrets.token_urlsafe(24)`，确认成功即作废）；旧标签 `revision` 不匹配、`confirmation_token` 不匹配或 nonce 已消费均返回 409。两类授权例外见 3.7 节。首次收款人核对是**操作者对虚构姓名与尾号的确认**，不是 KYC，也不验证账户归属。

4.7 执行与幂等

执行顺序固定为“先写审计 → 置 `PROCESSING` → 单一幂等键执行 → 按同一键查询”。工具超时或抛错时**不自动重提**，只查询已记录状态；查不到即 `UNKNOWN`，由用户显式查询。

4.8 隐私与数据最小化

- 结构化输入拒绝 `password/pin/cvv/otp/token/api_key/secret/account_number/card_number/pan` 等字段名，只记录被拒字段路径，不记录其值。
- 查询与预览输出按键名递归脱敏：敏感键丢弃，账号类键保留后 4 位，长数字串遮盖；有效日期保留。
- 加固版补充：验证码、校验码、动态码、短信码、口令、密码、安全码等关键词后的 4—8 位数字统一遮罩为 ••••。
- 审计不写原始聊天与原始 payload；用户、会话、收款姓名以 HMAC 标识化。
- **例外**：聊天原文保存在会话内存并原样回显给本人（渲染为纯文本），审计与日志不包含该文本。

4.9 审计

JSONL 追加 + SHA-256 前链 + 每行 `fsync` + 打开时校验；追加失败会阻止资金操作。加固版为每条事件增加 `event_mac = HMAC-SHA-256(key, event_hash)`：只有链没有密钥时，改写任何一条事件都会让签名对不上，`AuditLog.verify()` 会同时报告哈希链与签名两类不一致。

仍然要说清楚边界：演示密钥来自源码或环境变量，没有 KMS/HSM，也没有外部锚定或 WORM，拿到密钥和文件的人依旧可以重算整条链。签名把“随手改一行”的门槛提高了，但**不等于不可篡改**。

4.10 大模型接入安全

表 19 模型接入控制

面	控制
密钥保管	仅存于进程内存 `APIConfig`（`repr=False`），不落盘、不进配置文件、不出现在快照与日志；回显自动擦除
传输	仅允许公网 `https`（本机回环可 `http`）；拒绝内网、保留地址与 `.local/.internal/.lan` 等内部域名；禁止跟随重定向，避免 Authorization 头被转发到第三方
输入	上下文只含本轮合成数据与最近 12 条对话；发送前做长度截断与脱敏
输出	逐层校验 `choices/message/tool_calls` 结构；工具名正则、参数长度与 JSON 类型、重复调用 ID 全部校验
权限	模型不能确认交易、不能提交认证/风险字段、不能用内部收款人引用；每轮最多一次变更加工具
降级	模型异常返回固定文案，**不自动改用关键词通道**办理，避免“换个通道就办了”

4.11 供应链与交付完整性

运行时零第三方依赖（`pyproject.toml` 中 `dependencies = []`），显著缩小供应链面。Windows 免安装包内置的 CPython 来自官方 embeddable 发行版，构建时校验官方 SHA-256；交付清单 `DELIVERY_MANIFEST.json` 覆盖 96 个文件的 SHA-256，本次核对 0 处不匹配。CI 使用最小权限（`permissions: contents: read`）并在 Ubuntu/Windows × Python 3.11/3.13 上跑回归。

5 接口与数据模型

5.1 本机 HTTP 接口

表 20 HTTP 接口

方法与路径	用途	关键约束
GET /、/app.css、/app.js、/favicon.svg	静态资源白名单	仅四条固定路由；其余 404
GET /api/state	建立/读取会话并返回概览快照	无会话时创建（上限 30）；概览查询受认证与审计约束
POST /api/message	提交指令；action=authenticate 用演示安全码升级认证；确认/取消收款人；重置演示	Origin + CSRF + revision + request_id 缺一不可
POST /api/model	配置 / 断开 / 测试模型连接	同上；地址必须 HTTPS（回环可 http）；key 仅存内存

POST /api/message 的请求体字段：request_id（8—100 字符，用于去重）、revision（整数，防旧标签提交）、message（1—3 000 字）、action（可选：reset / authenticate / confirm_recipient / cancel_recipient）、factor（authenticate 时的 6 位演示安全码）、recipient_token、confirmation_token（一次性 nonce）、payload（收款人姓名与尾号）、source（chat 时走模型通道）。GET /api/state 的快照新增 auth 字段，包含当前渠道、是否增强认证以及当前演示安全码与到期时间。

5.2 核心数据模型

表 21 核心数据模型

模型	字段要点	说明
OperationRequest	operation、user_id、session_id、summary、payload、request_id、channel	不可变数据类；payload 在提交时深拷贝
AgentTask	state、risk、preview、prepared、choices、confirmation_*、idempotency_key、result	public_dict() 只暴露可公开字段，内部引用与幂等键不外泄
OperationPreview	summary、amount、currency、payer/payee_last4、fee、execute_at、reversible、details	public_dict() 会再做一次脱敏

模型	字段要点	说明
RiskAssessment	level、flags、manual_review_required、rule_ids	由工具给出，核心只做合并与提升
ExecutionResult	state、transaction_reference、error_code、details	工具返回值，是状态判定的唯一依据

5.3 工具协议

tools.py 定义 9 个 Protocol：AuthenticationTool、RiskAssessmentTool、AccountQueryTool、PublicInformationTool、TransferResolverTool、PreviewTool、ExecutionTool、StatusQueryTool、ManualReviewTool。核心只依赖协议，不依赖具体实现；因此把模拟银行替换为真实适配器时，状态机、认证、风险与确认逻辑不需要改动——但真实适配器必须自己实现鉴权、事务与幂等语义。

5.4 审计事件结构

```
{
  "event_id": "uuid",            "timestamp": "UTC ISO8601",
  "prev_hash": "前一条 event_hash", "event_hash": "本条规范化 SHA-256",
  "plan_id": "任务编号",          "step_id": "事件动作名",
  "user_id_hash": "HMAC",        "session_id_hash": "HMAC",
  "channel": "app|im|other",     "operation_type": "transfer",
  "risk_level": "R3",            "policy_version": "virtual-demo-1.0",
  "amount": "1288.00",           "currency": "CNY",   "account_last4": "1234",
  "counterparty_hash": "HMAC(收款人姓名)",
  "confirmation": {"required": true, "received": true, "summary_hash": "…", "expires_at":
"…"},
  "tool_name": "execution",      "idempotency_key": "uuid",
  "result": "success",           "error_code": null
}
```

6 部署与运行

6.1 环境要求

表 22 环境要求

形态	要求
源码运行	Windows 10/11 或任意桌面系统；Python 3.11+；无需安装任何第三方包；无需联网
免安装包	Windows x64；解压即用（包内 `runtime/` 自带 CPython 3.13.17）；无需管理员权限
模型通道	可选；需要浏览器能访问模型服务（默认 DeepSeek / 通义千问 / OpenAI 或自定义兼容接口）
网络	默认只监听 `127.0.0.1`；除可选的模型 API 外不发起任何外部请求

6.2 启动方式

```
# 网页演示（源码）
python -X utf8 launch_demo.py --web

# 命令行演示（源码）
python -X utf8 -m banking_agent --demo

# 全量回归
python -X utf8 -m unittest discover -s tests -v

# 免安装包：双击 启动网页演示.cmd
```

6.3 主要配置项

表 23 配置项

配置项	演示取值	作用
`low_risk_limit`	1 000 CNY	达到该金额把转账提升到 R3
`high_risk_limit`	10 000 CNY	单笔达到该金额直接 R4
`daily_transfer_limit`	20 000 CNY	当日累计达到该金额升级 R4
`investment_confirm_limit`	5 000 CNY	投资金额风险参数
`confirmation_ttl`	300 秒	预览确认有效期
网页直转阈值	严格小于 3 000 CNY	独立的网页授权例外，与风险参数无关

配置项	演示取值	作用
audit_hash_key_env	BANKING_AGENT_AUDIT_HASH_KEY	独立入口的标识化密钥环境变量
DEMO_TODAY	2026-10-29	固定演示业务日期，样例与验收脚本不随真实日期漂移
会话上限 / 空闲回收	30 个 / 30 分钟	LRU 淘汰，不再用 503 拒绝新会话
并发与读超时	24 个连接 / 10 秒	超限直接 503，慢连接不再占用线程

6.4 模型通道配置

在网页右上角“模型设置”中选择服务商、填写 Base URL、模型名与 API Key，保存后点“测试连接”。密钥只保存在当前浏览器会话的服务端内存中，断开或重启即消失；页面不会回显密钥。未配置模型时，聊天由确定性规则解析器处理，功能不受影响。

6.5 常见问题

表 24 常见问题

现象	原因与处理
页面提示“请在本地演示页面内操作”	Host/Origin 不匹配：请用启动窗口显示的 http://127.0.0.1:端口 打开
页面提示需要增强认证	当前处于 IM 演示渠道：在页面「安全认证」输入显示的 6 位演示安全码，或发送“认证 123456”
提示安全码错误或已过期	安全码一次性且 5 分钟有效：刷新页面查看最新安全码后再试
提示“AI 连接未完成”	模型接口不可达或密钥无效：检查网络、Base URL 与额度；不影响本地模拟业务
data/startup-error.log 有内容	启动阶段异常，可作为反馈附件；其中可能包含本机绝对路径

7 测试与验证

7.1 测试组织

测试使用标准库 `unittest`，共 162 个用例，覆盖核心 Agent、虚拟银行业务、网页接口、首次收款人、虚构股票、启动器、模型传输与模型工具校验，以及本轮加固新增的认证、确认、金额、限额、审计与脱敏控制。

表 25 测试分布

测试模块	用例数	覆盖范围
`test_agent.py`	14	失败关闭、预览绑定、确认过期、人工审核、幂等、超时、审计与脱敏
`test_demo.py`	32	账单、转账、AA、定时、理财、卡片、订阅、计划、预算与组合依赖
`test_web.py`	14	Host/Origin/CSRF、会话隔离、revision、小额直转与 3 000 元边界
`test_recipients.py`	15	首次核对前不扣款、确认保存、取消、重放、姓名边界、会话隔离
`test_stocks.py`	5	固定报价、费用、余额、幂等、确认门与审计保护
`test_llm_agent.py`	41	工具白名单、参数校验、默认值一致性、单轮单变更、降级
`test_llm_client.py`	15	URL 校验、内网地址拒绝、重定向拒绝、响应结构、密钥擦除
`test_web_llm.py`	8	网页模型通道端到端、首次核对不被模型绕过
`test_launcher.py`	4	启动器工作目录、缺文件诊断、缺 Python 提示
`test_hardening.py`	14	认证不可自证、一次性安全码、股票确认门、金额量化、共享限额、脱敏、审计签名、会话淘汰
合计	162	—

7.2 本次实测结果

在 Windows x64 + 内置 CPython 3.13 环境下执行全量用例，**162 项全部通过（失败 0、错误 0、跳过 0）**。加固前曾出现 7 项因测试硬编码 `2026-11-01` 到期而失败；本轮把演示业务

日期固定为 `DEMO_TODAY = 2026-10-29`，从根上消除了“样例随真实时间过期”的问题，也让回归结果可复现。

另执行 29 项 HTTP 黑盒探测（认证升级、确认 nonce、股票确认门、金额边界、跨会话限额、会话淘汰、并发去重、响应头与路径穿越等），**29 项全部符合预期**。其中“一句话切换到 APP”返回认证未提升、“1e999 元”被拒绝、第三次跨会话转账被限额拦截，三项直接对应加固前的缺陷。

7.3 验证边界

自动化用例验证的是“列出的回归路径符合断言”，不构成渗透测试、模糊测试、形式化证明或生产合规认证。未进行：外部渗透测试、自动化浏览器安全扫描、真实网络/数据库故障注入、高并发与跨进程一致性验证。

附录 A 演示脚本与预期现象

```
# 首次收款人（网页）
给张三转账 2888 元          → 弹出身份核对，未扣款；确认尾号后活期 50000.00 → 47112.00
给张三转账 25 元            → 已核对联系人，直接付款 → 47087.00
给张三转账 3000 元          → 需核对摘要并确认（恰好 3000 不适用小额直转）

# 命令行
看 2026-10 账单
给小明转账 300 元 → 确认转账
风险测评 地区：虚构区，目标：稳健长期配置，期限：3 年，流动性：中，R2，经验：新手，金额：5000 元
买入 XH001 100 股 → 确认投资操作 → 股票持仓

# 认证加固（网页与命令行一致）
切换到 IM                          → 降级为即时通讯（标准认证）
切换到 APP                         → 只提示“不能只靠一句指令”，认证不变
认证 123456                        → 用页面/终端显示的 6 位演示安全码完成增强认证

# 金额边界（加固后）
给小明转账 1e999 元                 → 拒绝：金额格式无法识别
给小明转账 1,000,000 元             → 拒绝：金额格式无法识别
给小明转账 1.005 元                 → 拒绝（文本渠道）：金额请使用两位小数

# 组合计划
组合计划：查余额；现在从活期转账 25 元给小明用途午餐；临时锁卡尾号 9012
继续组合计划
```

附录 B 文件清单

表 26 文件清单

路径	说明
banking_agent/agent.py	编排核心与状态机
banking_agent/web_app.py	本机 HTTP 与网页会话
banking_agent/demo.py	合成业务数据与模拟工具
banking_agent/llm_agent.py / llm_client.py	模型规划与传输
banking_agent/policy.py / config.py / models.py	策略、配置与数据模型
banking_agent/audit.py / privacy.py	审计与脱敏
banking_agent/workflow.py / stocks.py / tools.py	工作流、股票、工具协议
banking_agent/web/	原生前端（HTML/CSS/JS/SVG）
tests/	148 项自动化用例
docs/	架构、算法、安全、权限、风险与测试文档
runtime/	免安装版内置 CPython 运行时

文档结束。配套材料：《安全自评报告》（权限分级实现、控制项测评、已知风险清单与整改路线图）。